Red teaming and responsible disclosure



AI security · University · Lesson 4

In this lesson you will

- Plan a red-team exercise with permission, scope and a stop rule.
- Build an evaluation: pass rates per category, severity, regression tests.
- Report and disclose responsibly.

Remember

- Permission and scope before any test.
- One overall score hides weak categories: report each one.
- Owner first, time to fix, then the lesson, never the exploit.

Rules of engagement

1. Scope (5 min): Which system, version and accounts?
2. Rules (5 min): Test data, a stop rule, a contact.
3. Bank (6 min): Ten mild cases in three categories.
4. Report (4 min): Draft the finding template.

Only systems you own or have written permission to test, and mild, made-up requests only.

Let’s discuss

1. Why does a red team need written permission?
2. What can an overall pass rate hide?
3. Why publish the lesson but not the exploit?

Check yourself

- Write the first line of a finding: what you tried, what got through, and its severity.